

Le workflow des dossiers (« tickets ») sur eVDP

Comment un signalement devient un **Case**, et comment ce Case traverse une machine à états stricte — de la soumission à la clôture — avec un contrôle d'accès par capacité à chaque étape sensible.

Document basé sur le code réel de `apps/coordination/workflow.py`, illustré par un dossier réellement traité en simulation le 11 septembre 2026.

01

Qu'est-ce qu'un « ticket » dans eVDP ?

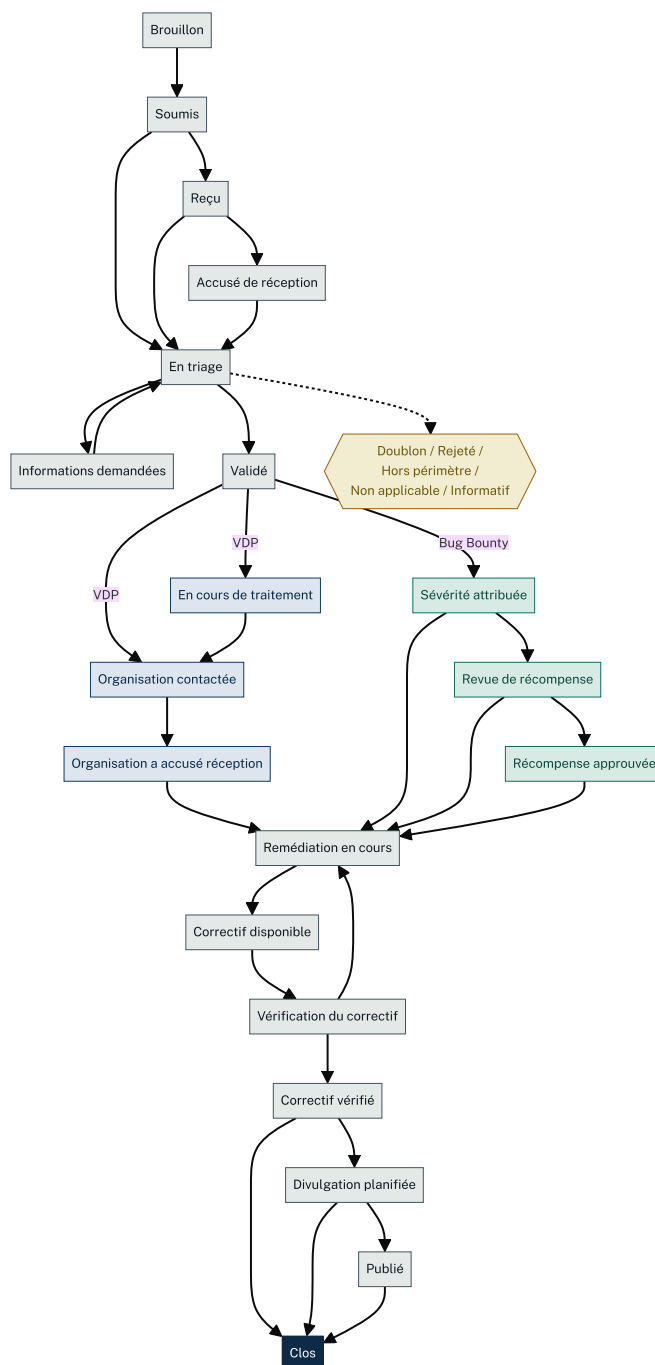
Le terme technique est `Case` (dossier). C'est l'objet qui porte tout le cycle de vie d'un signalement une fois transformé en dossier de traitement — distinct du `VulnerabilityReport` brut soumis par le déclarant, qui lui n'est jamais modifié après coup.

Chaque Case porte, entre autres :

- un `statut` parmi **25 valeurs possibles** (l'objet de ce document) ;
- un `workflow` : **CVD/VDP** ou **Bug Bounty** — chacun a ses propres transitions autorisées ;
- une `priorité` recalculée automatiquement (sévérité, ancienneté, dépassement SLA) ;
- un historique complet (`CaseStatusHistory`) et une chronologie publique-source (`CaseTimelineEvent`).

Diagramme de flux

Un tronc commun (réception, triage, validation) puis une **bifurcation** selon le type de programme : le VDP part directement en coordination avec l'organisation, le Bug Bounty passe par l'attribution de sévérité puis la revue de récompense. Les deux se rejoignent en remédiation.



 Spécifique au canal VDP
 Spécifique au canal Bug Bounty
 Issues de clôture sans suite

 État terminal (Clos)

Comment lire ce diagramme, étape par étape

1. **Tronc commun (gris)** — de `Soumis` à `Validé`, tout dossier suit exactement le même chemin, quel que soit le canal : réception, accusé, triage, éventuel aller-retour « informations demandées ».
2. **Sortie de secours en pointillés** — depuis `En triage`, cinq issues de clôture sans suite (doublon, rejeté, hors périmètre, non applicable, informatif) restent accessibles à tout moment sans passer par la validation.
3. **La bifurcation, au nœud `Validé`** — c'est le seul point de divergence réel : le VDP (bleu) part directement en coordination avec l'organisation affectée ; le Bug Bounty (vert) passe d'abord par l'attribution de sévérité, puis la revue de récompense.
4. **Reconvergence en Remédiation** — les deux canaux se rejoignent ensuite sur un chemin unique (correctif, vérification, divulgation, clôture) : la distinction VDP / Bug Bounty n'existe que dans la partie haute du graphe.

Règle absolue du moteur : `check_transition()` refuse toute transition non explicitement déclarée dans `VDP_TRANSITIONS` ou `BOUNTY_TRANSITIONS` — y compris rester sur le même état. Aucun saut d'étape n'est possible depuis l'interface, même par erreur.

Voir cette branche en action : l'exemple traité section 05 suit précisément la branche **Bug Bounty (verte)** de ce diagramme, du nœud `Validé` jusqu'à `Clos` — chaque flèche franchie y est datée et attribuée à un compte réel.

Les 25 statuts, regroupés par phase

Chaque transition sensible exige une **capacité RBAC** précise (au-delà du simple droit de changer un statut)
— colonne « Capacité exigée ».

STATUT	CANAL	SIGNIFICATION	CAPACITÉ EXIGÉE
RÉCEPTION			
Brouillon	Partagé	Rapport non encore soumis (usage interne, transitoire)	CHANGE_CASE_STATUS
Soumis	Partagé	Point d'entrée : le dossier vient d'être créé à la soumission	CHANGE_CASE_STATUS
Reçu	Partagé	Accusé de réception donné au déclarant (SLA 72h)	CHANGE_CASE_STATUS
Accusé de réception	Partagé	Variante explicite avant passage en triage	CHANGE_CASE_STATUS
TRIAGE			
En triage	Partagé	Équipe CSIRT en cours d'analyse (SLA 5 jours ouvrés)	CHANGE_CASE_STATUS
Informations demandées	Partagé	En attente d'un complément du déclarant, retour possible au triage	CHANGE_CASE_STATUS
Validé	Partagé	Vulnérabilité confirmée réelle par reproduction	TRIAGE_CASE
Doublon / Rejeté / Hors périmètre / Non applicable / Informatif	Issues	Clôture sans suite — accessibles depuis presque tout état d'analyse	TRIAGE_CASE
SPÉCIFIQUE VDP			
En cours de traitement	VDP	Prise en charge interne avant contact formel de l'organisation	CHANGE_CASE_STATUS
Organisation contactée	VDP	L'organisation affectée a été notifiée du rapport technique	CHANGE_CASE_STATUS
Organisation a accusé réception	VDP	Confirmation de prise en charge côté organisation	CHANGE_CASE_STATUS
SPÉCIFIQUE BUG BOUNTY			
Sévérité attribuée	Bug Bounty	Sévérité confirmée, dossier prêt pour proposition de récompense	SET_SEVERITY
Revue de récompense	Bug Bounty	Un montant a été proposé, en attente de décision	PROPOSE_BOUNTY
Récompense approuvée	Bug Bounty	Montant validé par un compte distinct de celui qui a proposé	APPROVE_BOUNTY
REMÉDIATION			

STATUT	CANAL	SIGNIFICATION	CAPACITÉ EXIGÉE
Remédiation en cours	Partagé	Le correctif est en cours de développement (SLA 30 à 90 jours selon sévérité)	CHANGE_CASE_STATUS
Correctif disponible	Partagé	Le correctif a été déployé, en attente de vérification	CHANGE_CASE_STATUS
Vérification du correctif	Partagé	Le CSIRT re-teste le scénario original	CHANGE_CASE_STATUS
Correctif vérifié	Partagé	Le correctif est confirmé efficace	CHANGE_CASE_STATUS
DIVULGATION ET CLÔTURE			
Divulgation planifiée	Partagé	Une date de publication a été fixée (défaut : 90 jours)	CHANGE_CASE_STATUS
Publié	Partagé	L'advisory public est en ligne	PUBLISH_ADVISORY
Clos	Terminal	Fin de cycle — plus aucune transition sortante	CHANGE_CASE_STATUS

04

Vue Kanban : 7 colonnes pour 25 statuts

L'interface ne montre jamais les 25 statuts bruts sur le tableau visuel — `kanban_column_for()` les regroupe en 7 colonnes compréhensibles d'un coup d'œil.

SOUMIS	TRIAGE	VALIDÉ	REMÉDIATION	VÉRIFICATION	DIVULGATION	CLOS
Soumis	En triage	Validé	En cours	Vérif.	Planifiée	Clos
Reçu	Infos dem.	Sévérité	Org. cont.	Vérifié	Publié	Rejeté
Accusé		Revue réc.	Org. rép.			Doublon
		Réc. appr.	Remédiation			+3 autres
			Correctif			

Simulation à l'appui : un dossier réel, du dépôt à la clôture

Ce n'est pas un exemple théorique : dossier réellement créé et traité sur l'instance de démonstration eVDP le 11 septembre 2026, avec changement de compte à chaque étape pour respecter la séparation des rôles. Il parcourt exactement la branche **Bug Bounty** du diagramme de la section 02, du tronc commun jusqu'à la reconvergence en remédiation.

EVDP-2026-000009 · Bug Bounty · Ministère de la Santé et de l'Hygiène Publique

IDOR sur l'API dossier patient permettant de consulter les dossiers d'autres usagers

1 — → SOUMIS

13:52 · zata_sec (chercheur, compte + email vérifié + MFA)

Signalement créé directement au statut Soumis.

2 SOUMIS → REÇU → EN TRIAGE

13:55 · Agent de triage · capacité `CHANGE_CASE_STATUS`

3 EN TRIAGE → VALIDÉ

13:57 · Analyste CSIRT · capacité `TRiage_CASE`

Qualification préalable : sévérité Élevée, CVSS 6,5, CWE-639 (IDOR).

4 VALIDÉ → SÉVÉRITÉ ATTRIBUÉE

13:57 · Analyste CSIRT · capacité `SET_SEVERITY`

5 SÉVÉRITÉ ATTRIBUÉE → REVUE DE RÉCOMPENSE

14:01 · Analyste CSIRT · capacité `PROPOSE_BOUNTY`

Proposition de 650 000 XOF (suggestion matrice : 900 000 XOF).

6 REVUE DE RÉCOMPENSE → RÉCOMPENSE APPROUVÉE

14:01 · **Coordinateur national** (compte distinct) · capacité `APPROVE_BOUNTY`

Séparation des rôles : celui qui propose n'approuve jamais lui-même.

7 RÉCOMPENSE APPROUVÉE → REMÉDIATION → CORRECTIF DISPO. → VÉRIFICATION → CORRECTIF VÉRIFIÉ

14:01–14:02 · Coordinateur national · capacité `CHANGE_CASE_STATUS`

Versement de 650 000 XOF enregistré (Mobile Money) entre les étapes 6 et 7.

8 CORRECTIF VÉRIFIÉ → DIVULGATION PLANIFIÉE

14:02 · Coordinateur national · date fixée : 10/12/2026

9 DIVULGATION PLANIFIÉE → PUBLIÉ → CLOS

14:07 · Coordinateur national · capacité `PUBLISH_ADVISORY`

Advisory EVDP-ADV-2026-000003 publié, crédit rendu au pseudonyme « zata_sec ».

15 minutes, 9 transitions, 4 comptes distincts (chercheur, agent de triage, analyste, coordinateur) — chacune vérifiée par `check_transition()` avant d'être acceptée.

Règles structurelles à retenir

États terminaux

`Clos`, `Rejeté`, `Doublon`, `Hors périmètre`, `Non applicable` : aucune transition sortante n'existe depuis ces états dans le code actuel — une réouverture nécessiterait une intervention hors workflow standard.

Double vérification à chaque transition

`check_transition()` exige à la fois la capacité spécifique à l'état cible (ex. `APPROVE_BOUNTY`) et la capacité générale `CHANGE_CASE_STATUS` — avoir l'une sans l'autre ne suffit pas.

Vue publique volontairement floue

La page de suivi anonyme ne montre jamais les 25 statuts : `PUBLIC_STATUS_BUCKETS` les réduit à 5 libellés (Reçu, En cours d'analyse, Correction en cours, Résolu, Clôturé sans suite) — la file d'attente interne et les motifs exacts de clôture restent invisibles au déclarant.

Aucun raccourci possible

Même un Coordinateur national qui détient toutes les capacités ne peut pas sauter d'étape : `can_transition()` vérifie l'existence explicite de l'arête dans le dictionnaire de transitions avant toute capacité — la structure du graphe prime sur les droits de l'utilisateur.